Bloque 1: Introducción, Gobernanza y el Ciclo de Desarrollo Seguro

FADENA

Arquitectura Zero Trust y Marcos Corporativos

Ing. Roxana Quiroga Sollinger



MSDL Parte 2

Módulo 2: Arquitectura Zero Trust y Marcos Corporativos

FADENA

2.1 Arquitectura y gobierno Zero Trust

2.2 Microsoft Security Development Lifecycle

2.3 Seguridad en DevSecOps



Módulo 1: Fundamentos de Seguridad en el Software

FADENA

Microsoft Security Development Lifecycle



2.2 Microsoft Security Development Lifecycle

- La necesidad del SDL
- Prácticas del SDL

  (https://www.microsoft.com/en-us/securityengineering/sdl/practices)
- **Integración con DevOps**



2.2 Microsoft Security Development Lifecycle

Integración con DevOps

Cultura y Estrategia

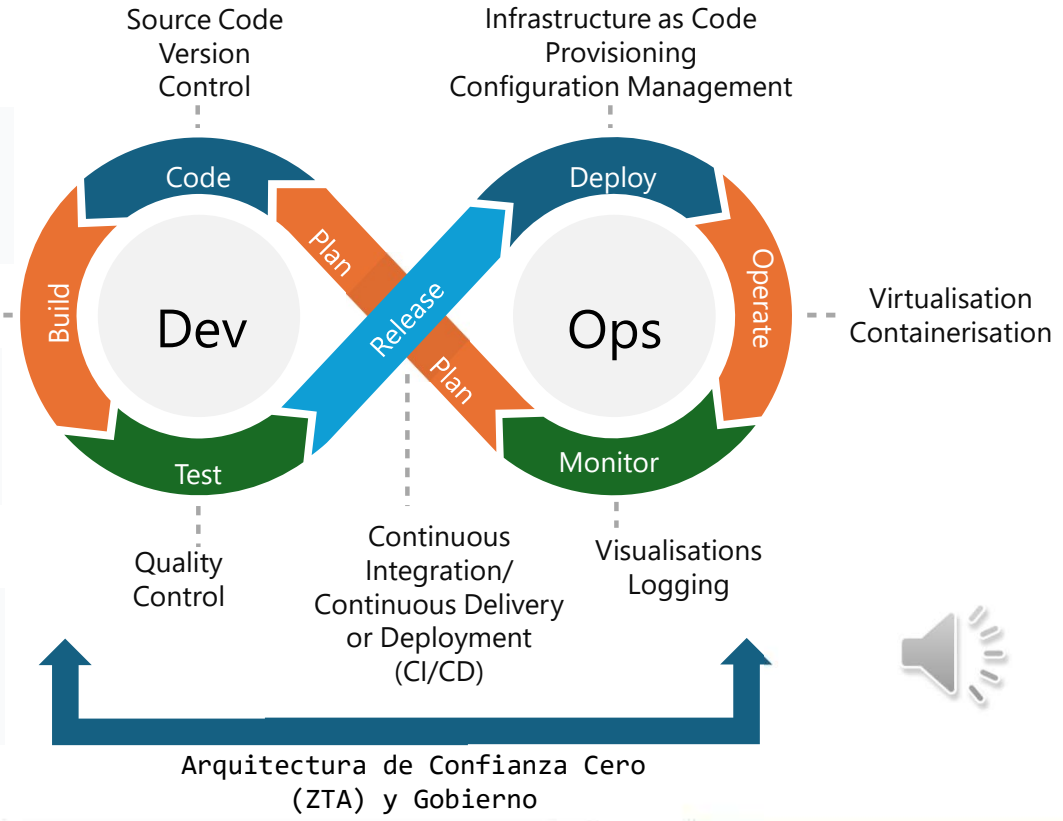
Las cargas de trabajo exitosas deben cumplir su función, ser confiables y estar disponibles cuando se necesiten, y no deben permitir que personas no autorizadas abusen de ellas ni de los datos que utilizan.

Prácticas y controles de seguridad

La implementación de controles técnicos es fundamental para que la seguridad se convierta en una realidad y para que los atacantes sean bloqueados, detectados y neutralizados. Las 10 prácticas deben aplicarse en todas las actividades de desarrollo.

Procesos

Los procesos integran la cultura y los controles técnicos en el trabajo diario de las personas para hacerlo real y mantener los resultados en el tiempo. Los procesos DevSecOps deben ser integrales, con mejora continua y pragmáticos.

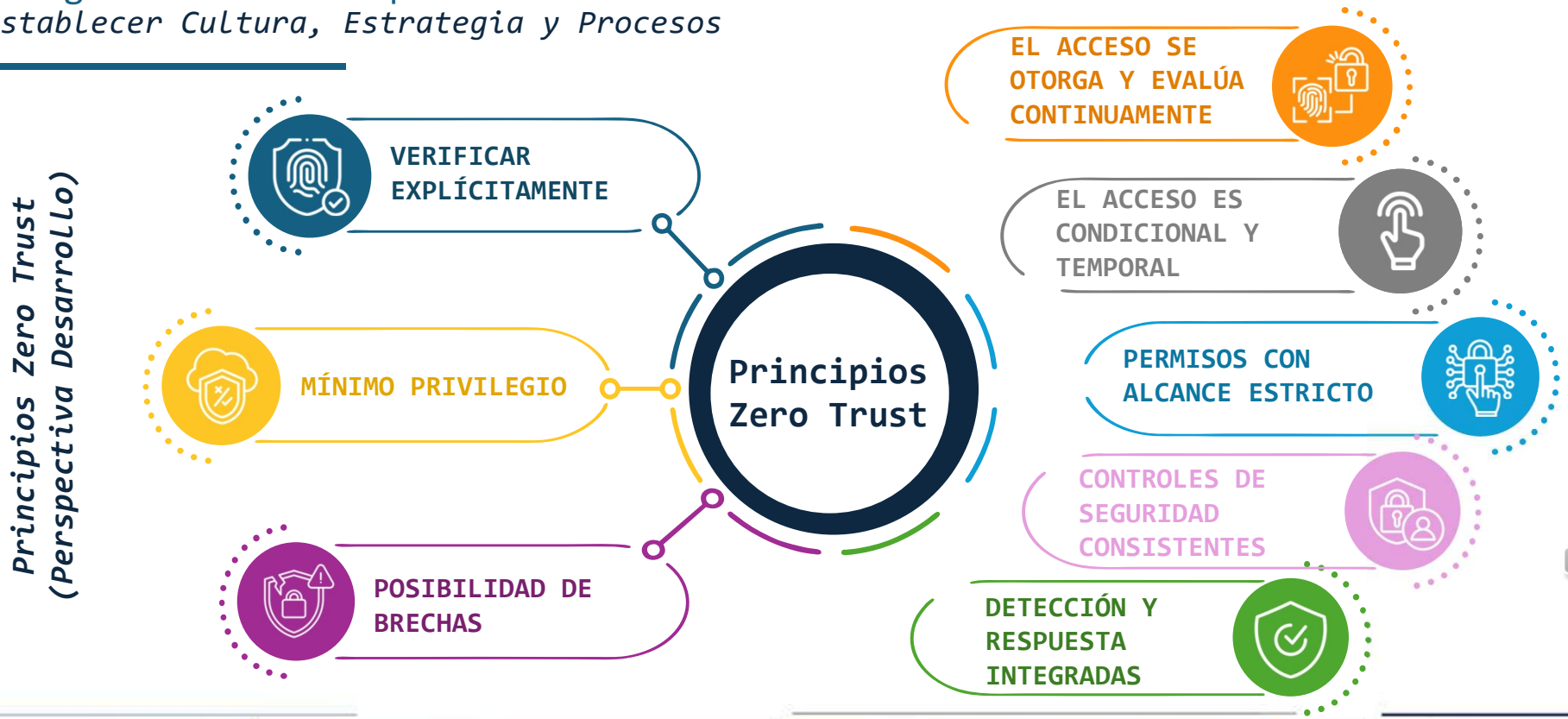


FADENA

2.2 Microsoft Security Development Lifecycle

Integración con DevOps

Establecer Cultura, Estrategia y Procesos



2.2 Microsoft Security Development Lifecycle

Integración con DevOps

Establecer Cultura, Estrategia y Procesos

3 Reducción de Riesgos

Eliminar la dependencia de contraseñas mitiga amenazas comunes en el trabajo remoto, como los ataques de fuerza bruta, justificando la transición hacia la autenticación passwordless.



1 Delegación de Identidad

Delegar la gestión a de identidades que permita usar sus tokens e integrar automáticamente autenticación multifactor (MFA), políticas de acceso condicional y mecanismos sin contraseña.

2 Integración de seguridad

Los tokens conectan la aplicacon de forma fluida con el ecosistema completo de trabajo.

FADENA

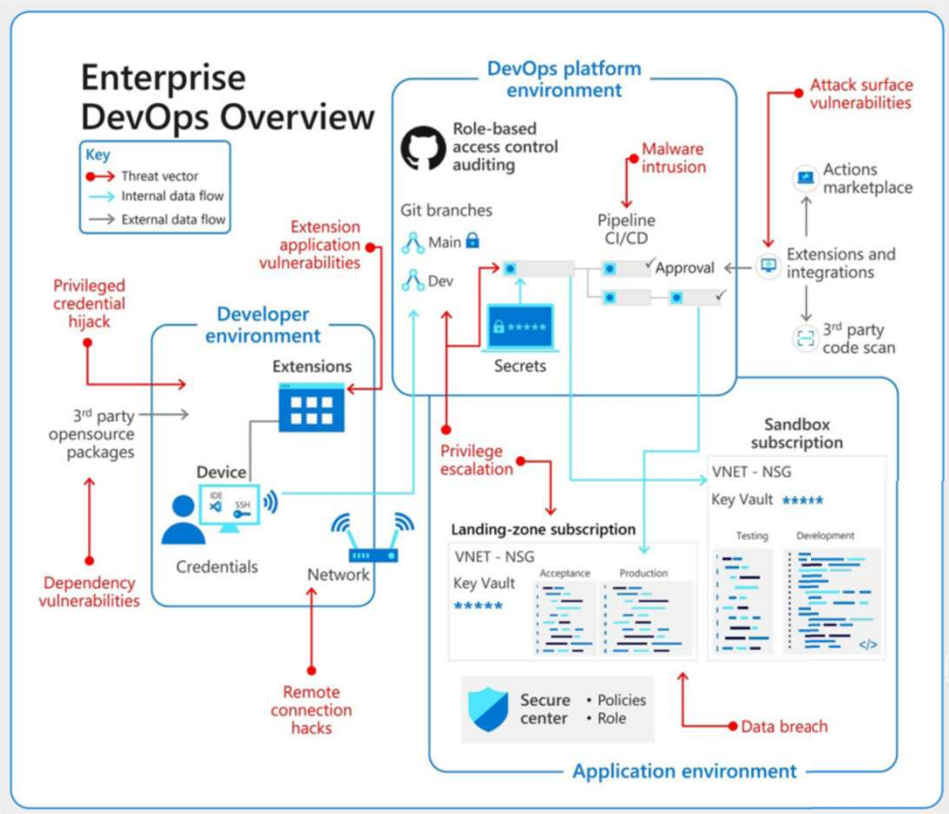
2.2 Microsoft Security Development Lifecycle

Integración con DevOps

Definir Prácticas de Seguridad y Control

- SEGURIZAR EL AMBIENTE DE DESARROLLO
- SEGURIZAR LA PLATAFORMA DEVOPS
- SEGURIZAR EL AMBIENTE DE LA APLICACIÓN
- INCLUIR ZT EN LA CADENA DE SUMINISTRO

Panorama de Amenazas de DevOps



2.2 Microsoft Security Development Lifecycle

Integración con DevOps

Definir Prácticas de Seguridad y Control

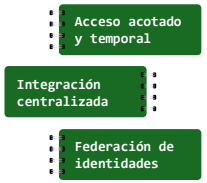
Segurizar el ambiente de desarrollo

Controlar el entorno de desarrollo

La centralización de los controles ofrece una capa de gobernanza a los equipos de DevOps cuando deben cumplir con requisitos adicionales para desarrolladores, ya sean de redes, acceso, credenciales o certificados.

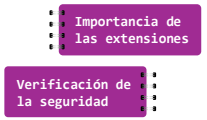
Configurar el acceso con privilegios mínimos

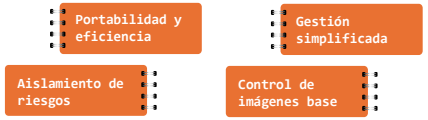
El uso del principio de mínimo privilegio y el acceso justo a tiempo no solo es una buena práctica para los administradores de sistemas y los usuarios finales, sino también para Enterprise DevOps.



Adoptar sólo herramientas, extensiones e integraciones de confianza

Asegurarse de que sus equipos se tomen el tiempo necesario para integrar únicamente herramientas de mercados y proveedores confiables.





Proteger el entorno de desarrollo con contenedores.

Los contenedores permiten a los equipos de DevOps implementar entornos de desarrollo portátiles, seguros y reproducibles tanto en la nube como en dispositivos locales.

Limitar quién puede modificar y aprobar el código con seguridad de ramas

Para proteger el sistema contra modificaciones no autorizadas, es indispensable implementar una estrategia de ramificación con ramas protegidas y revisiones de código.

2.2 Microsoft Security Development Lifecycle

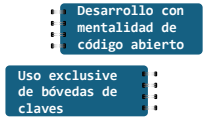
Integración con DevOps

Definir Prácticas de Seguridad y Control

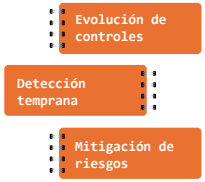
Segurizar la plataforma DevOps

Asegurar de que ningún miembro del equipo tenga acceso a secretos y certificados

Las plataformas DevOps y sus canalizaciones son un objetivo prioritario de ciberataques debido a los permisos de alto nivel que gestionan y a que han quedado fuera de los controles de seguridad.



Automatice los análisis de plantillas de Infraestructura como Código (IaC)



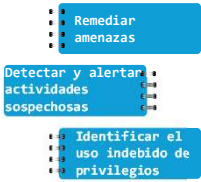
Para proteger los entornos de Infraestructura como Código (IaC) y garantizar el cumplimiento normativo, los equipos de DevOps deben automatizar la verificación de seguridad y políticas dentro de sus procesos de trabajo.

Automatizar los flujos de trabajo de aprobación

Para que cualquier flujo de trabajo de aprobación implemente código en producción, ciertas comprobaciones automáticas o manuales deben confirmar la seguridad, el valor comercial, el estado y la calidad de cada solicitud.

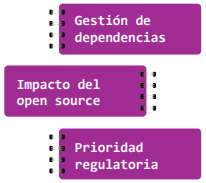
Implementar cada plataforma DevOps con registros de auditoría

Es fundamental extender el registro de auditoría de los entornos de producción a todas las plataformas DevOps y canalizaciones de CI/CD, documentando el usuario, el cambio realizado y la fecha/hora del evento.



Proteger la cadena de suministro de software

Con cada biblioteca que incorporas a tu código, expandes la cadena de suministro de software y heredas dependencias de cada proyecto o herramienta de código abierto.



Permitir solo integraciones verificadas de herramientas DevOps

Al igual que en los entornos de desarrollo, las herramientas DevOps incluyen numerosas extensiones e integraciones para que el equipo DevOps sea eficiente y seguro.

2.2 Microsoft Security Development Lifecycle

Integración con DevOps

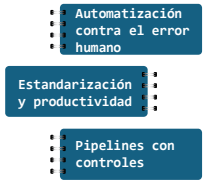
Definir Prácticas de Seguridad y Control

Segurizar el ambiente de la aplicación



Utilizar el marco de arquitectura bien diseñada (WAF)para el aprovisionamiento de zonas de aterrizaje

Una zona de aterrizaje segura basada en un Marco de Arquitectura Bien Diseñada (WAF) es fundamental para proteger entornos en la nube a través de sus cinco pilares

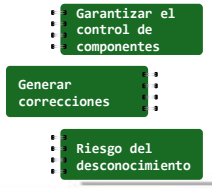


Proteger los entornos con segmentación

La segmentación en ciberseguridad reduce la superficie de ataque y limita el impacto de una intrusión mediante la creación de barreras físicas y lógicas en redes e identidades.

Corregir las vulnerabilidades rápidamente con un SBOM

La falta de visibilidad sobre los sistemas en producción genera graves riesgos de seguridad, mientras que la combinación de un inventario claro y la automatización permite responder a las vulnerabilidades de forma casi instantánea.



Proporcionar visibilidad de los flujos de entrega a los equipos de seguridad

La integración e intercambio de datos entre los equipos de DevOps y los de seguridad permite detectar vulnerabilidades antes de llegar al entorno de producción

2.2 Microsoft Security Development Lifecycle

Integración con DevOps

Definir Prácticas de Seguridad y Control

Segurizar DevOps en la práctica

Enseñar las mejores prácticas de DevSeOps

- Causas de incumplimiento en políticas de seguridad
- Políticas de priorización y documentación clara
- Colaboración multidsisciplinaria

Transicionar a equipos DevOps centrados en el producto.

Las organizaciones migran de modelos centralizados por proyectos a equipos de producto DevOps descentralizados, los cuales asumen la responsabilidad completa de todo el ciclo de vida del .

